

ENCUESTA INTEGRAL DE CIBERSEGURIDAD MERCURY

Kit de Evaluación para Organizaciones Españolas | Versión 2.0 | Enero 2026

INSTRUCCIONES DE ADMINISTRACIÓN

Esta encuesta está diseñada para evaluar la madurez de ciberseguridad en organizaciones españolas alineadas con:

- NIS2 (Directiva 2022/2555 UE)
- ISO/IEC 27001:2022
- NIST Cybersecurity Framework v2.0
- Metodología Mercury AVRQ

Público Objetivo

- Directores de Seguridad de la Información (CISO)
- Responsables de Cumplimiento Normativo
- Directores Técnicos (CTO)
- Responsables de Gestión de Riesgos
- Auditores Internos y Externos

Tiempo Estimado de Respuesta

- Completo: 90-120 minutos
- Modular: 20-30 minutos por sección
- Mínimo esencial: 45 minutos

Instrucciones de Respuesta

1. Seleccione la opción que mejor refleja la situación actual de su organización
2. Si desconoce la información, marque "Sin datos disponibles" o "Desconoce"
3. Las preguntas de escala Likert (1-5) funcionan así:
4. 1: Inexistente / Ad hoc / Manual
5. 2: Básico / Inicial / Documentado parcialmente
6. 3: Definido / Establecido / Documentado completamente
7. 4: Gestionado / Medido / Automatizado parcialmente
8. 5: Optimizado / Continuo / Totalmente automatizado

SECCIÓN 1: DATOS GENERALES DE LA ORGANIZACIÓN

P1.1 Información Básica

Nombre de la organización: _____

Sector:

- ☐ Energía y Utilities

- ☐ Transporte
- ☐ Finanzas y Seguros
- ☐ Sanidad
- ☐ Telecomunicaciones
- ☐ Administración Pública
- ☐ Educación
- ☐ Manufactura
- ☐ Tecnología
- ☐ Otro: _____

Tamaño de la organización:

- ☐ Microempresa (<10 empleados)
- ☐ Pequeña (10-49 empleados)
- ☐ Mediana (50-249 empleados)
- ☐ Grande (250-999 empleados)
- ☐ Muy grande (>1.000 empleados)

Clasificación NIS2:

- ☐ Entidad Esencial (EE)
- ☐ Entidad Importante (EI)
- ☐ Proveedor crítico de servicios digitales
- ☐ No clasificado / No aplica

P1.2 Gobernanza y Estructura Organizativa

¿Existe una estructura formal de ciberseguridad en la organización?

- ☐ Sí, con CISO/responsable dedicado a tiempo completo
- ☐ Sí, con responsable dedicado a tiempo parcial
- ☐ Sí, pero asignaciones ad hoc sin dedicación formal
- ☐ No existe estructura formal
- ☐ Desconoce

¿El responsable de ciberseguridad reporta directamente a la Dirección o Consejo?

- ☐ Sí, al Consejo de Administración o Junta Directiva
- ☐ Sí, al Director General o equivalente
- ☐ Sí, al Director de Operaciones o Servicios Técnicos
- ☐ No, reporta a nivel intermedio
- ☐ No reporta formalmente
- ☐ Desconoce

¿Existe un Comité de Ciberseguridad con participación multifuncional?

- ☐ Sí, con reuniones regulares mensuales o más frecuentes
- ☐ Sí, con reuniones trimestrales
- ☐ Sí, pero con reuniones irregulares

- ☐ Existe informalmente
- ☐ No existe
- ☐ Desconoce

SECCIÓN 2: GESTIÓN DE RIESGOS DE CIBERSEGURIDAD

P2.1 Marco de Gestión de Riesgos

¿Dispone la organización de una metodología formal de análisis y evaluación de riesgos?

- ☐ Sí, basada en ISO 27005:2022 o equivalente
- ☐ Sí, basada en NIST SP 800-30 o similar
- ☐ Sí, basada en metodología propietaria
- ☐ Sí, pero sin alineación con estándares internacionales
- ☐ No existe metodología formal
- ☐ Desconoce

¿Con qué frecuencia se realiza análisis de riesgos de ciberseguridad?

- ☐ Continuo (evaluación en tiempo real)
- ☐ Anual
- ☐ Bianual
- ☐ Cuando hay cambios significativos
- ☐ Irregularmente
- ☐ Nunca / No se realiza
- ☐ Desconoce

¿Se documentan y aprueban formalmente los riesgos aceptados?

- ☐ Sí, con aprobación de Junta Directiva
- ☐ Sí, con aprobación de Dirección ejecutiva
- ☐ Sí, con aprobación de jefe de departamento
- ☐ Parcialmente
- ☐ No se documentan formalmente
- ☐ Desconoce

P2.2 Cuantificación de Riesgos (Enfoque Mercury/AVRQ)

¿La organización cuantifica riesgos cibernéticos en términos monetarios?

- ☐ Sí, utilizando metodología FAIR o equivalente
- ☐ Sí, utilizando metodología Mercury AVRQ
- ☐ Sí, utilizando otra metodología cuantitativa
- ☐ Parcialmente (solo para ciertos tipos de riesgo)
- ☐ No, solo evaluación cualitativa
- ☐ Desconoce

¿Se valorizan los activos de la organización para cálculo de impacto?

- ☐ Sí, con valuación exhaustiva y actualizada

- ☐ Sí, pero solo para activos críticos identificados
- ☐ Parcialmente; existen valuaciones parciales
- ☐ No existe valuación formal
- ☐ Desconoce

¿Se analiza el retorno sobre inversión (ROI) en medidas de ciberseguridad?

- ☐ Sí, sistemáticamente para todas las inversiones
- ☐ Sí, pero solo para proyectos mayores (>€100K)
- ☐ Parcialmente; análisis ad hoc
- ☐ No se realiza análisis ROI
- ☐ Desconoce

P2.3 Tratamiento y Mitigación de Riesgos

¿Existen planes formales de tratamiento de riesgos (mitigación, aceptación, transferencia)?

- ☐ Sí, documentados y con propietarios identificados
- ☐ Sí, pero sin propietarios formales
- ☐ Parcialmente
- ☐ No existen planes formales
- ☐ Desconoce

¿Se monitorizan y revisan regularmente los planes de tratamiento?

- ☐ Mensualmente o con mayor frecuencia
- ☐ Trimestralmente
- ☐ Semestralmente
- ☐ Anualmente
- ☐ Irregularmente
- ☐ Nunca se revisan
- ☐ Desconoce

¿Qué porcentaje de riesgos identificados tiene plan de tratamiento asignado?

- ☐ 100% (todos los riesgos)
- ☐ 80-99%
- ☐ 60-79%
- ☐ 40-59%
- ☐ 20-39%
- ☐ <20%
- ☐ Desconoce

SECCIÓN 3: VULNERABILIDADES Y GESTIÓN DE VULNERABILIDADES

P3.1 Identificación de Vulnerabilidades

¿Con qué frecuencia se realizan escaneos de vulnerabilidades?

- ☐ Continuo (diario o múltiples veces por semana)

- ☐ Semanal
- ☐ Quincenal
- ☐ Mensual
- ☐ Trimestral
- ☐ Anual o menos
- ☐ Nunca / No se realizan
- ☐ Desconoce

¿Se han clasificado y documentado todos los activos de TI de la organización?

- ☐ Sí, con inventario exhaustivo y actualizado automáticamente
- ☐ Sí, con inventario manual actualizado periódicamente
- ☐ Parcialmente; existe inventario pero con gaps
- ☐ No existe inventario formal
- ☐ Desconoce

¿Qué herramientas se utilizan para identificar vulnerabilidades? (Seleccione todas las aplicables)

- ☐ Escáneres de vulnerabilidades automatizados (ej: Qualys, Nessus, OpenVAS)
- ☐ Herramientas de análisis estático de código (SAST)
- ☐ Herramientas de análisis dinámico de código (DAST)
- ☐ Análisis manual por expertos
- ☐ Inteligencia de amenazas / Threat Intelligence feeds
- ☐ No se utilizan herramientas formales
- ☐ Desconoce

P3.2 Priorización y Remediación de Vulnerabilidades

¿Se utiliza un sistema de puntuación (scoring) para priorización de vulnerabilidades?

- ☐ Sí, CVSS (Common Vulnerability Scoring System)
- ☐ Sí, EPSS (Exploit Prediction Scoring System)
- ☐ Sí, sistema propietario
- ☐ Sí, pero básico/manual
- ☐ No existe sistema formal
- ☐ Desconoce

¿Cuál es el Tiempo Medio de Remediación (MTTR) de vulnerabilidades críticas?

- ☐ <7 días
- ☐ 7-14 días
- ☐ 15-30 días
- ☐ 31-60 días
- ☐ >60 días
- ☐ Desconoce / No se mide

¿Existe un Service Level Agreement (SLA) para remediación de vulnerabilidades?

- ☐ Sí, documentado y comunicado

- ☐ Sí, pero sin documentación formal
- ☐ Parcialmente; SLA para ciertos niveles de severidad
- ☐ No existe SLA
- ☐ Desconoce

P3.3 Gestión de Parches

¿Con qué frecuencia se aplican parches de seguridad críticos?

- ☐ Dentro de 7 días de su disponibilidad
- ☐ Dentro de 14 días
- ☐ Dentro de 30 días
- ☐ Dentro de 60 días
- ☐ >60 días o irregular
- ☐ Desconoce

¿Se rastrea y reporta la tasa de cobertura de parches?

- ☐ Sí, >95% de sistemas cubiertos
- ☐ Sí, 85-95%
- ☐ Sí, 70-84%
- ☐ Parcialmente; <70%
- ☐ No se rastrea
- ☐ Desconoce

¿Se utiliza un sistema automatizado de gestión de parches?

- ☐ Sí, completamente automatizado
- ☐ Sí, parcialmente automatizado
- ☐ Parcialmente; mezcla manual y automatizado
- ☐ No, proceso completamente manual
- ☐ Desconoce

SECCIÓN 4: PRUEBAS DE PENETRACIÓN Y EVALUACIÓN DE SEGURIDAD

P4.1 Pruebas de Penetración

¿Se realizan pruebas de penetración (pen-testing)?

- ☐ Sí, anualmente con equipo interno
- ☐ Sí, anualmente con tercero externo
- ☐ Sí, bianualmente
- ☐ Sí, irregularmente
- ☐ No se realizan
- ☐ Desconoce

¿Se evalúan los hallazgos de penetración y se implementan correcciones?

- ☐ Sí, con plan formalizado y seguimiento
- ☐ Sí, pero sin plan formal

- ☐ Parcialmente
- ☐ Los hallazgos se documentan pero no se actúa
- ☐ No se evalúan
- ☐ Desconoce

¿Se incluyen pruebas de penetración social (phishing, ingeniería social)?

- ☐ Sí, regularmente (>2 veces/año)
- ☐ Sí, anualmente
- ☐ Sí, pero raramente
- ☐ No se incluyen
- ☐ Desconoce

P4.2 Evaluaciones de Seguridad y Auditorías

¿Se realizan evaluaciones de seguridad de aplicaciones?

- ☐ Sí, antes de cada release en producción
- ☐ Sí, anualmente
- ☐ Sí, pero irregularmente
- ☐ No se realizan
- ☐ Desconoce

¿Existen auditorías internas de ciberseguridad?

- ☐ Sí, anualmente con equipo interno especializado
- ☐ Sí, anualmente con auditor externo
- ☐ Sí, bianualmente
- ☐ Sí, irregularmente
- ☐ No existen
- ☐ Desconoce

¿Se ha obtenido certificación ISO/IEC 27001?

- ☐ Sí, y está vigente
- ☐ Sí, pero expirada
- ☐ En proceso de certificación
- ☐ Planeado para futuro próximo
- ☐ No está en planes
- ☐ Desconoce

SECCIÓN 5: GESTIÓN DE INFORMACIÓN Y EVENTOS DE SEGURIDAD (SIEM)

P5.1 Infraestructura SIEM

¿Dispone la organización de un sistema SIEM?

- ☐ Sí, SIEM completo (ej: Splunk, ArcSight, ELK Stack)
- ☐ Sí, SIEM simplificado o cloud-based (ej: Azure Sentinel, Datadog)
- ☐ Parcialmente; agregación de logs pero no análisis avanzado

- ☐ No existe SIEM; logs distribuidos en múltiples sistemas
- ☐ Desconoce

¿Quién gestiona el SIEM?

- ☐ Equipo SOC (Security Operations Center) interno dedicado
- ☐ Equipo TI/Infraestructura interno
- ☐ Proveedor de servicios gestionados (MSSP)
- ☐ Combinación de interno y externo
- ☐ No hay responsable claro
- ☐ Desconoce

¿Cuántos eventos de log se procesan diariamente en el SIEM?

- ☐ >10 millones de eventos/día
- ☐ 5-10 millones/día
- ☐ 1-5 millones/día
- ☐ 100K-1 millón/día
- ☐ <100K/día
- ☐ Desconoce

P5.2 Detección y Alertas

¿Se han definido reglas de correlación y alertas en el SIEM?

- ☐ Sí, >100 reglas activas, personalizadas para la organización
- ☐ Sí, 50-100 reglas
- ☐ Sí, <50 reglas
- ☐ Sí, pero basadas en configuración default
- ☐ No existen reglas personalizadas
- ☐ Desconoce

¿Cuál es la tasa de falsos positivos (false positive rate) del SIEM?

- ☐ <5% (excelente)
- ☐ 5-10% (bueno)
- ☐ 10-20% (aceptable)
- ☐ 20-50% (alto)
- ☐ >50% (muy alto)
- ☐ No se mide
- ☐ Desconoce

¿Se rastrea el Tiempo Medio de Detección (MTTD)?

- ☐ Sí, y es <1 hora para amenazas críticas
- ☐ Sí, y es <4 horas
- ☐ Sí, y es <24 horas
- ☐ Parcialmente; se rastrea pero sin SLA definido

- ☐ No se rastrea
- ☐ Desconoce

P5.3 Respuesta a Incidentes

¿Se automatiza alguna respuesta a través del SIEM (SOAR)?

- ☐ Sí, automatización completa para ciertas amenazas
- ☐ Sí, automatización parcial (playbooks para casos comunes)
- ☐ Sí, pero limitada
- ☐ No existe automatización
- ☐ Desconoce

¿Cuál es el Tiempo Medio de Respuesta (MTTR) para incidentes detectados?

- ☐ <1 hora
- ☐ 1-4 horas
- ☐ 4-24 horas
- ☐ 1-7 días
- ☐ >7 días
- ☐ No se mide
- ☐ Desconoce

¿Se registran y analizan todos los incidentes de seguridad?

- ☐ Sí, con análisis forense y post-mortem
- ☐ Sí, con documentación formal
- ☐ Parcialmente; solo los críticos
- ☐ Se registran pero sin análisis formal
- ☐ No se registran sistemáticamente
- ☐ Desconoce

SECCIÓN 6: CAPACITACIÓN EN SEGURIDAD DE EMPLEADOS

P6.1 Programa de Concienciación en Seguridad

¿Existe un programa formal de capacitación en ciberseguridad?

- ☐ Sí, obligatorio para todos los empleados anualmente
- ☐ Sí, pero opcional o selectivo
- ☐ Sí, pero irregular/no planificado
- ☐ Existe informalmente
- ☐ No existe
- ☐ Desconoce

¿Cuál es la tasa de participación en capacitación de ciberseguridad?

- ☐ 100% (todos los empleados)
- ☐ 80-99%
- ☐ 60-79%

- ☐ 40-59%
- ☐ 20-39%
- ☐ <20%
- ☐ Desconoce

¿Qué formatos se utilizan para capacitación? (Seleccione todas las aplicables)

- ☐ Formación presencial/webinar en vivo
- ☐ Cursos online (e-learning)
- ☐ Micro-aprendizaje (short videos, tips, infografías)
- ☐ Simulaciones prácticas
- ☐ Gamificación (juegos, competencias)
- ☐ Documentación (guías, políticas)
- ☐ Otras: _____

P6.2 Evaluación del Aprendizaje

¿Se evalúa el conocimiento adquirido en capacitación?

- ☐ Sí, con quizzes/exámenes regulares
- ☐ Sí, pero solo evaluación inicial post-training
- ☐ Sí, pero irregularmente
- ☐ Se evalúa informalmente
- ☐ No se evalúa
- ☐ Desconoce

¿Se mide la retención de conocimiento en el tiempo?

- ☐ Sí, con evaluaciones periódicas (trimestral, semestral)
- ☐ Sí, pero anualmente
- ☐ No se mide
- ☐ Desconoce

¿Cuál es el porcentaje promedio de aprobación en evaluaciones?

- ☐ >90% (excelente)
- ☐ 80-90% (bueno)
- ☐ 70-80% (aceptable)
- ☐ 60-70% (bajo)
- ☐ <60% (muy bajo)
- ☐ No se mide
- ☐ Desconoce

P6.3 Pruebas de Phishing y Cumplimiento

¿Se realizan simulaciones de phishing?

- ☐ Sí, mensualmente
- ☐ Sí, trimestralmente
- ☐ Sí, semestralmente

- ☐ Sí, anualmente
- ☐ Raramente
- ☐ Nunca
- ☐ Desconoce

¿Cuál es la tasa de clics en emails de phishing simulado?

- ☐ <5% (excelente)
- ☐ 5-10% (bueno)
- ☐ 10-20% (aceptable)
- ☐ 20-40% (preocupante)
- ☐ >40% (crítico)
- ☐ No se mide
- ☐ Desconoce

¿Existen consecuencias educativas (no punitivas) para empleados que caen en phishing?

- ☐ Sí, capacitación inmediata específica
- ☐ Sí, material educativo remitido
- ☐ Sí, pero inconsistente
- ☐ No existe programa
- ☐ Desconoce

P6.4 Tasa de Reporte de Amenazas

¿Se incentiva el reporte de amenazas de seguridad?

- ☐ Sí, con botón de reporte fácilmente accesible
- ☐ Sí, pero requiere pasos complicados
- ☐ Parcialmente
- ☐ No existe incentivo claro
- ☐ Desconoce

¿Cuál es la tasa de reporte de emails maliciosos por empleados?

- ☐ >50% de emails maliciosos (excelente)
- ☐ 30-50% (bueno)
- ☐ 10-30% (aceptable)
- ☐ 5-10% (bajo)
- ☐ <5% (muy bajo)
- ☐ No se mide
- ☐ Desconoce

¿Se proporcionan comentarios (feedback) a empleados después de reportar una amenaza?

- ☐ Sí, retroalimentación inmediata y educativa
- ☐ Sí, pero con retraso
- ☐ Parcialmente

- ☐ No se proporciona feedback
- ☐ Desconoce

SECCIÓN 7: CUMPLIMIENTO NORMATIVO Y GOBERNANZA

P7.1 Conformidad NIS2

¿Conoce si su organización está sujeta a la Directiva NIS2?

- ☐ Sí, es Entidad Esencial
- ☐ Sí, es Entidad Importante
- ☐ Sí, pero clasificación pendiente
- ☐ No está clasificado
- ☐ Desconoce
- ☐ No aplica (fuera de jurisdicción UE)

¿Cuál es el estado actual de conformidad con NIS2?

- ☐ Totalmente conforme
- ☐ Conforme con la mayoría de requisitos (>90%)
- ☐ Parcialmente conforme (60-90%)
- ☐ En fase inicial de cumplimiento (<60%)
- ☐ No ha comenzado cumplimiento
- ☐ Desconoce

¿Se ha designado un responsable de notificación de incidentes bajo NIS2?

- ☐ Sí, con contacto documentado ante autoridades
- ☐ Sí, pero sin notificación formal ante autoridades
- ☐ Parcialmente asignado
- ☐ No se ha designado
- ☐ Desconoce

P7.2 Conformidad ISO 27001

¿Está certificado bajo ISO/IEC 27001?

- ☐ Sí, certificación vigente
- ☐ Sí, certificación expirada
- ☐ En proceso de certificación
- ☐ Planeado para próximos 12 meses
- ☐ No está planeado
- ☐ Desconoce

¿Qué cobertura tiene el alcance de ISO 27001?

- ☐ Toda la organización
- ☐ Áreas críticas/seleccionadas
- ☐ Departamento específico (ej: TI)

- ☐ No aplica
- ☐ Desconoce

P7.3 Políticas y Documentación

¿Existe una Política de Seguridad de la Información documentada?

- ☐ Sí, actualizada en últimos 12 meses
- ☐ Sí, actualizada hace 1-2 años
- ☐ Sí, pero no actualizada hace >2 años
- ☐ No existe política formal
- ☐ Desconoce

¿Se documentan y comunican todas las políticas de ciberseguridad?

- ☐ Sí, documentadas y comunicadas formalmente a todos
- ☐ Sí, documentadas pero comunicación limitada
- ☐ Parcialmente
- ☐ No existen políticas formales
- ☐ Desconoce

¿Con qué frecuencia se revisan las políticas?

- ☐ Anualmente
- ☐ Cada 2 años
- ☐ Irregularmente
- ☐ Nunca / No se revisan
- ☐ Desconoce

SECCIÓN 8: CONTINUIDAD Y RECUPERACIÓN ANTE DESASTRES

P8.1 Plan de Continuidad de Negocio (BCP) y Recuperación ante Desastres (DR)

¿Existe un Plan de Continuidad de Negocio (BCP)?

- ☐ Sí, documentado y probado regularmente
- ☐ Sí, documentado pero no probado
- ☐ Sí, pero sin documentación formal
- ☐ No existe plan
- ☐ Desconoce

¿Existe un Plan de Recuperación ante Desastres (DR)?

- ☐ Sí, con RPO <4 horas y RTO <24 horas
- ☐ Sí, con RPO <24 horas y RTO <48 horas
- ☐ Sí, pero con SLA más largo
- ☐ Existe pero sin métricas definidas
- ☐ No existe plan
- ☐ Desconoce

¿Se realizan pruebas regulares de recuperación?

- ☐ Sí, anualmente como mínimo
- ☐ Sí, pero cada 2 años
- ☐ Raramente
- ☐ Nunca se han realizado pruebas
- ☐ Desconoce

P8.2 Copias de Seguridad

¿Se realizan copias de seguridad de datos críticos?

- ☐ Sí, diariamente o más frecuente
- ☐ Sí, semanalmente
- ☐ Sí, mensualmente
- ☐ Sí, pero irregularmente
- ☐ No se realizan
- ☐ Desconoce

¿Se rastrea y verifica la integridad de copias de seguridad?

- ☐ Sí, verificación automática regular
- ☐ Sí, verificación manual periódica
- ☐ Parcialmente
- ☐ No se verifica
- ☐ Desconoce

¿Se prueban regularmente las restauraciones de copia de seguridad?

- ☐ Sí, anualmente como mínimo
- ☐ Sí, pero cada 2 años
- ☐ Raramente
- ☐ Nunca
- ☐ Desconoce

SECCIÓN 9: SEGURIDAD DE LA CADENA DE SUMINISTRO

P9.1 Evaluación de Proveedores

¿Se evalúan los proveedores de servicios críticos desde perspectiva de ciberseguridad?

- ☐ Sí, evaluación formal previa a contratación y periódica
- ☐ Sí, pero solo previa a contratación
- ☐ Parcialmente
- ☐ No existe evaluación formal
- ☐ Desconoce

¿Se especifican requisitos de ciberseguridad en contratos con proveedores?

- ☐ Sí, con cláusulas detalladas y SLAs
- ☐ Sí, pero genéricos

- ☐ Parcialmente
- ☐ No se especifican
- ☐ Desconoce

¿Se monitorizan incidentes de ciberseguridad de proveedores críticos?

- ☐ Sí, mediante inteligencia de amenazas dedicada
- ☐ Sí, pero de forma reactiva
- ☐ Parcialmente
- ☐ No se monitoriza
- ☐ Desconoce

P9.2 Gestión de Software y Dependencias

¿Se rastrea el inventario de software y librerías (SBOM)?

- ☐ Sí, SBOM automático y actualizado continuamente
- ☐ Sí, SBOM manual actualizado periódicamente
- ☐ Parcialmente
- ☐ No existe SBOM
- ☐ Desconoce

¿Se monitorizan vulnerabilidades en dependencias de software?

- ☐ Sí, automáticamente con herramientas dedicadas
- ☐ Sí, de forma manual
- ☐ Parcialmente
- ☐ No se monitorizan
- ☐ Desconoce

SECCIÓN 10: INFRAESTRUCTURA Y CONTROLES TÉCNICOS

P10.1 Autenticación y Control de Acceso

¿Se implementa autenticación multifactor (MFA)?

- ☐ Sí, para todos los accesos críticos y administrativos
- ☐ Sí, para accesos administrativos
- ☐ Sí, pero solo para VPN/acceso remoto
- ☐ No se implementa
- ☐ Desconoce

¿Se gestiona centralizadamente el control de acceso (IAM)?

- ☐ Sí, con sistema centralizado (ej: Active Directory, Okta)
- ☐ Sí, pero con múltiples sistemas
- ☐ Parcialmente
- ☐ No existe gestión centralizada
- ☐ Desconoce

¿Se realiza revisión de derechos de acceso regularmente?

- ☐ Sí, anualmente como mínimo
- ☐ Sí, pero cada 2 años
- ☐ Raramente
- ☐ Nunca
- ☐ Desconoce

P10.2 Encriptación

¿Se encriptan datos en tránsito (HTTPS, TLS)?

- ☐ Sí, para todas las comunicaciones sensibles
- ☐ Sí, pero con excepciones
- ☐ Parcialmente
- ☐ No se implementa
- ☐ Desconoce

¿Se encriptan datos en reposo?

- ☐ Sí, para datos críticos
- ☐ Sí, pero solo en ciertos sistemas
- ☐ Parcialmente
- ☐ No se implementa
- ☐ Desconoce

¿Se gestiona centralizadamente la clave de encriptación?

- ☐ Sí, mediante HSM o servicio de gestión de claves
- ☐ Sí, pero de forma manual
- ☐ Parcialmente
- ☐ No existe gestión centralizada
- ☐ Desconoce

P10.3 Seguridad Perimetral y Red

¿Se implementan firewalls?

- ☐ Sí, firewalls perimetrales + interiores (Zero Trust)
- ☐ Sí, solo firewall perimetral
- ☐ Sí, pero desactualizado
- ☐ No se implementan
- ☐ Desconoce

¿Se segmenta la red?

- ☐ Sí, segmentación según criticidad y función
- ☐ Sí, segmentación básica
- ☐ Parcialmente
- ☐ No existe segmentación
- ☐ Desconoce

¿Se implementan sistemas de detección/prevención de intrusiones (IDS/IPS)?

- ☐ Sí, IPS activo en puntos críticos
- ☐ Sí, IDS en modo monitoreo
- ☐ Parcialmente
- ☐ No se implementan
- ☐ Desconoce

P10.4 Protección de Endpoints

¿Se implementa antivirus/antimalware en endpoints?

- ☐ Sí, en 100% de dispositivos
- ☐ Sí, en >90%
- ☐ Sí, pero <90%
- ☐ No se implementa
- ☐ Desconoce

¿Se utiliza Endpoint Detection and Response (EDR)?

- ☐ Sí, en todos los endpoints críticos
- ☐ Sí, pero en porcentaje limitado
- ☐ No se implementa
- ☐ Desconoce

¿Se implementa control de dispositivos (DLP)?

- ☐ Sí, control exhaustivo de todos los dispositivos
- ☐ Sí, pero selectivo
- ☐ Parcialmente
- ☐ No se implementa
- ☐ Desconoce

SECCIÓN 11: INTELIGENCIA DE AMENAZAS E INVESTIGACIÓN

P11.1 Threat Intelligence

¿Se utiliza inteligencia de amenazas (threat intelligence)?

- ☐ Sí, feeds comerciales integrados en SIEM
- ☐ Sí, feeds de fuentes públicas
- ☐ Sí, pero con uso limitado
- ☐ No se utiliza
- ☐ Desconoce

¿Se participa en iniciativas de información compartida?

- ☐ Sí, en sectores-specific ISACs (ej: FinCERT, SectorCERT)
- ☐ Sí, en iniciativas públicas (ej: INCIBE, CCN-CERT)
- ☐ Parcialmente

- ☐ No participa
- ☐ Desconoce

P11.2 Análisis Forense e Investigación

¿Se realiza análisis forense en caso de incidentes?

- ☐ Sí, con equipo interno especializado
- ☐ Sí, con apoyo externo
- ☐ Parcialmente
- ☐ No se realiza
- ☐ Desconoce

¿Se mantiene registro de cadena de custodia (chain of custody)?

- ☐ Sí, procedimiento formal documentado
- ☐ Sí, pero sin formalidad
- ☐ Parcialmente
- ☐ No existe procedimiento
- ☐ Desconoce

SECCIÓN 12: EVALUACIÓN GENERAL Y COMENTARIOS

P12.1 Autoevaluación de Madurez

En una escala de 1-5, ¿cuál es el nivel de madurez general de ciberseguridad de su organización?

- 1 ☐ Ad hoc / Inicial (inexistentes o muy básicos controles)
- 2 ☐ Básico / En desarrollo (algunos controles documentados)
- 3 ☐ Definido / Establecido (controles documentados e implementados)
- 4 ☐ Gestionado / Medido (controles medidos y monitorizados)
- 5 ☐ Optimizado / Continuo (controles automatizados y en mejora continua)

P12.2 Principales Desafíos

¿Cuáles son los principales desafíos de ciberseguridad de su organización? (Seleccione hasta 3)

- ☐ Falta de presupuesto / recursos
- ☐ Escasez de personal especializado
- ☐ Tecnología desactualizada / legacy systems
- ☐ Complejidad de arquitectura / sistemas distribuidos
- ☐ Falta de gobernanza / apoyo ejecutivo
- ☐ Regulaciones complejas (NIS2, GDPR, etc.)
- ☐ Gestión de riesgos de cadena de suministro
- ☐ Capacitación insuficiente de empleados
- ☐ Otros: _____

P12.3 Comentarios Finales

¿Existe algún comentario adicional o información que desee compartir?

FIN DE LA ENCUESTA

Gracias por su participación. Los datos recopilados se utilizarán confidencialmente para evaluar la madurez de ciberseguridad y generar recomendaciones personalizadas.

Próximos pasos:

1. Se enviará un informe ejecutivo en 5 días hábiles
2. Sesión de retroalimentación con equipo ejecutivo (si aplica)
3. Plan de mejora personalizado

*Encuesta diseñada en conformidad con NIS2, ISO 27001, NIST CSF y Metodología Mercury AVRQ
Versión 2.0 | Enero 2026 | Ponferrada, Castilla y León*